

PCI-DSS & GDPR

Full Easy-English Study Notes, With Extra Examples for Understanding

Prepared for: Muhammad Shafiq Goraya

Track: Red Team / Penetration Testing

Style: Full detail, instructor Q&A style, real-world examples added for every concept

Covers: PCI-DSS full breakdown, Merchant Levels, SAQ/ASV/AOC/ROC/QSA, Requirement 11, Wireless testing, Rogue Access Points, GDPR overview, Article 32, Article 35 (DPIA), full quiz reviews

PCI-DSS

Merchant Levels

SAQ

ASV

AOC

ROC

QSA

WAP

Rogue Access Point

Quarterly Testing

GDPR

Article 32

DPIA / Article 35

What's Inside

- Part 1 — PCI-DSS: full concepts, terms, and quiz reviews with examples
- Part 2 — GDPR overview, Article 32, Article 35 (DPIA), with real-world scenarios
- Part 3 — Full revision summary + 10 keywords to memorize
- Part 4 — Homework and self-check questions

Part 1 · PCI-DSS — Full Detailed Notes

1. What is PCI-DSS?

Full Form

PCI = Payment Card Industry | DSS = Data Security Standard

Purpose

PCI-DSS exists to protect payment card information by defining clear security requirements that companies must follow when they store, process, or transmit card data.

Example for Understanding

Imagine a small clothing shop that accepts credit cards. PCI-DSS is like a rulebook that says: "If you want to accept Visa or Mastercard payments, you must lock your card data in a digital safe, limit who can access it, and test your systems regularly." Whether it's a small shop or a huge online retailer, everyone accepting cards must follow this rulebook — just at different levels of strictness.

2. Merchant Levels — Easy Rule

Merchant level tells us how "big" a business is, based on how many card transactions it processes every year. The bigger the business, the more transactions, and the more strict the security requirements become.

Level	Transactions / Year	Main Idea
Level 4	Less than 20,000	Small business
Level 3	20,000 – 1 Million	Medium business
Level 2	1 – 6 Million	Large business
Level 1	More than 6 Million	Largest business

Easy Rule to Remember

More transactions → More risk → More security requirements.

Example for Understanding

Think of it like traffic rules. A small local road (Level 4, like a corner shop) doesn't need as many traffic signals as a busy motorway (Level 1, like Amazon or a big airline). More traffic (transactions) means more chances of something going wrong, so more control is needed.

3. Important PCI-DSS Terms (with meaning and example)

SAQ — *Self-Assessment Questionnaire*

A security checklist that the company itself fills out to show it follows PCI-DSS rules — nobody external checks it for smaller merchants.

Example: A small online store (Level 4) fills out the SAQ themselves every year, answering questions like "Do you encrypt card data?" and "Do you use a firewall?"

ASV — *Approved Scanning Vendor*

An approved company that performs the required network vulnerability scans on behalf of the merchant.

Example: A large retailer hires an ASV every quarter to scan its network from outside and check for open ports or vulnerable systems that hackers could exploit.

AOC — *Attestation of Compliance*

A document confirming the organization follows PCI-DSS — like a signed declaration of compliance.

Example: After completing their SAQ or full assessment, a company signs an AOC saying "Yes, we meet all PCI-DSS requirements," and shares it with their bank or payment processor.

ROC — *Report on Compliance*

A detailed compliance report, usually required for the biggest merchants (Level 1).

Example: A large bank hires a QSA to produce a full ROC — a long, detailed document covering every single PCI-DSS requirement and how the company meets it.

QSA — *Qualified Security Assessor*

A certified assessor (a person or a company) who is officially qualified to perform PCI-DSS assessments.

Example: Think of a QSA like an auditor for a company's financial books, but instead of money, they check security controls — firewalls, encryption, access control, and more.

4. PCI-DSS Requirement 11

Main Idea

Regularly test security systems and processes.

Remember

Installing security is not enough. You must **Test it** → **Assess it** → **Improve it**.

Example for Understanding

Imagine you install a home alarm system. Requirement 11 says: don't just install it and forget it — test it every few months to make sure it still works, the battery isn't dead, and it actually alerts you when a door opens.

5. Wireless Access Point (WAP)

A WAP is a device that lets wireless devices connect to a network through Wi-Fi.

Example: A Wi-Fi router at home, or an enterprise access point mounted on the ceiling of an office building that lets employees' laptops and phones connect to the company network wirelessly.

6. Rogue Access Point Exam Keyword

Definition

A Rogue Access Point is an **unauthorized** wireless access point connected to the company network.

Remember

Not weak Not old Unauthorized — that is the key word the exam is testing.

Example for Understanding

Imagine an employee plugs in their own personal Wi-Fi router under their desk because the office Wi-Fi is slow. IT never approved this device. Now anyone within range — even someone sitting in the parking lot — could connect to this rogue access point and get inside the company network without going through proper security. That's exactly what a Rogue Access Point is.

7. Wireless Scanning

Purpose: Discover Wi-Fi networks, find rogue access points, check encryption, and verify wireless security.

Scan → Identify → Compare with IT inventory → Investigate unknown devices → Report

Example for Understanding

A pentester walks around the office building with a laptop running a wireless scanning tool. It picks up 12 Wi-Fi signals. The IT inventory list only has 10 approved access points. The pentester investigates the 2 unknown ones and finds one is an employee's personal router — a rogue access point! This gets flagged in the final report.

8. Quarterly Testing

Quarterly = Every 3 Months.

Why? Networks change constantly — new devices appear, employees join or leave, and new rogue access points can be installed at any time. Regular testing helps detect these changes and risks before they become a real problem.

Example for Understanding

Think of quarterly testing like a health check-up. Even if you feel fine, doctors recommend regular checkups because problems can develop silently. Similarly, even if a network "seems fine," quarterly scans catch new weaknesses before attackers find them first.

Part 2 · GDPR — Full Detailed Notes

1. What is GDPR?

Full Form

GDPR = General Data Protection Regulation (Not "Compliance" — this is a very common mistake to avoid on the exam.)

Purpose

Organizations dealing with the EU should perform security testing and assessments to help protect personal data and meet GDPR requirements.

Example for Understanding

Imagine a Pakistani software company builds an app used by customers in Germany and France. Even though the company is not based in the EU, because it collects and processes personal data of EU citizens, GDPR rules still apply to it.

Question: When should a penetration tester be aware of GDPR?

Correct Answer 10/10

A penetration tester should be aware of GDPR when the business or client is from the EU, is based in the EU, or has business dealings through EU systems.

Question: Does GDPR give a detailed penetration testing methodology?

Correct Answer 10/10

No. GDPR does not go into detailed technical steps. It mainly says that testing and assessment must be performed — the specific method is left up to the organization to decide.

Question: How can a penetration tester help a company with GDPR?

Full Answer 9.5/10

The main role of the penetration tester is to perform security testing and assessments that help organizations meet GDPR compliance requirements. This directly supports GDPR's overall goal of protecting the personal information (PII) of EU clients.

Instructor Tip — PCI-DSS vs GDPR (Very Important Distinction)

PCI-DSS says: "Here are specific security requirements and testing activities" — for example Merchant Levels, ASV, QSA, and quarterly wireless testing. It is very detailed and prescriptive.

GDPR (in your notes) says: "Organizations must perform security testing and assessment." It doesn't spend much time explaining exactly how to perform the penetration test — it focuses more on the outcome (protecting personal data) rather than the exact method.

Example for Understanding

Think of PCI-DSS like a strict recipe: "Use exactly 2 cups of flour, bake at 180°C for 25 minutes." GDPR is more like a general instruction: "Make sure the cake is safe to eat and test it before serving" — it trusts you to figure out the details.

Lesson 12 · GDPR Article 32

This is one of the two GDPR articles specifically highlighted for the PenTest+ exam.

Main Idea (from your notes)

Article 32 focuses on regularly testing, assessing, and evaluating the effectiveness of technical and organizational security measures.

Simple Example

A company says: "We installed a firewall." Article 32 asks: "Great... but have you tested whether it actually works?"

Another example — the company has IDS installed , antivirus installed , encryption enabled . Article 32 says: don't just install security — **test it regularly** to make sure it is truly effective.

This is very similar to what we learned in **PCI-DSS Requirement 11**: security must be tested regularly. Notice how both PCI-DSS and GDPR share this same underlying philosophy — "install it, then prove it works."

Install Security → Test It → Assess It → Evaluate It → Improve It

This is the security lifecycle that many security frameworks follow — not just GDPR.

Instructor's Note — Understanding the Key Verbs

Assess → Evaluate whether something is working correctly.

Test → Actively verify by performing security testing.

Evaluate → Review the results and decide if improvements are needed.

Example for Understanding

Imagine a school fire drill. "Installing" security is like putting up fire extinguishers. "Testing" is running the fire drill. "Assessing" is checking how fast everyone evacuated. "Evaluating" is deciding if the evacuation plan needs to be improved next time. Article 32 wants organizations to go through this entire cycle, not stop after step one.

Mini Quiz Review — Article 32

Q1: What is the main idea of GDPR Article 32? 10/10

Your answer: "Regular testing security" — Correct. A more complete version: GDPR Article 32 requires organizations to regularly test, assess, and evaluate the effectiveness of their security measures.

Q2: If a company installs a firewall but never tests it, does that follow Article 32? 10/10

Your answer: "No" — Correct. Installing security is not enough; it must also be tested regularly.

Q3: As a penetration tester, how do you help a company meet Article 32? 10/10

Your answer: "By testing security" — Correct. Full professional version: As a penetration tester, I test and assess the organization's security controls, identify vulnerabilities, verify that security measures are effective, and provide recommendations for improvement.

Lesson 13 · GDPR Article 35 (Final GDPR Topic)

What is Article 35?

Article 35 is about a **Data Protection Impact Assessment (DPIA)**.

Imagine This Situation

A hospital wants to launch a new online patient portal. The portal will store patient names, phone numbers, medical records, and national ID numbers.

Before launching it, the organization asks: "What could go wrong?" — Could hackers steal the data? Is personal data properly protected? Are there privacy risks?

This thinking process, done **before** the system is launched, is called a Data Protection Impact Assessment (DPIA).

Simple Definition

Think of a DPIA as a **risk assessment for personal data**. Before processing sensitive personal information, the organization identifies: What risks exist? How serious are they? How can we reduce them?

Example for Understanding

Imagine you are about to build a swimming pool in your backyard where children will play. Before building it, you think ahead: "What if a child falls in without supervision? What if the water isn't clean? Do we need a fence?" You plan safety measures before the pool is even built — that's exactly the mindset of a DPIA, but for personal data instead of a swimming pool.

How Does a Penetration Tester Help with a DPIA?

- Testing the application's security
- Finding vulnerabilities
- Showing where personal data could be exposed
- Recommending security improvements

This technical information helps the organization understand and reduce risk before real damage happens.

Example for Understanding

Going back to the hospital portal example: a penetration tester is brought in before launch. They find that the medical records page can be accessed by simply changing a number in the URL (an IDOR vulnerability). This finding becomes part of the DPIA — the hospital fixes it before real patients are ever exposed to that risk.

Final Quiz Review — GDPR

Q1: What does DPIA stand for?

Data Protection Impact Assessment.

Q2: What is the purpose of a DPIA?

To identify and reduce privacy risks before an organization processes sensitive personal data — essentially, to protect PII (Personally Identifiable Information).

Q3: When should an organization think about a DPIA?

Before processing sensitive personal data — not after a data breach. A DPIA is a proactive, "before launch" activity, not a reactive one.

Q4: As a penetration tester, how can your assessment help a DPIA?

By testing the application's security, finding vulnerabilities, showing where personal data could be exposed, and recommending improvements — giving the organization real technical evidence to support their risk assessment.

Part 3 · Full Revision Summary Sheet

PCI-DSS — Full Recap

- **PCI-DSS** = Payment Card Industry Data Security Standard — protects payment card information.
- **Merchant Levels**: Level 4 (smallest) to Level 1 (largest) — more transactions means more security requirements.
- **SAQ** = Self-Assessment Questionnaire (company checks itself).
- **ASV** = Approved Scanning Vendor (external company performs required scans).
- **AOC** = Attestation of Compliance (signed confirmation document).
- **ROC** = Report on Compliance (detailed compliance report, usually for Level 1).
- **QSA** = Qualified Security Assessor (certified person/company that assesses PCI-DSS compliance).
- **Requirement 11**: test security regularly, don't just install it and forget it.
- **WAP** = Wireless Access Point (device allowing Wi-Fi connections).
- **Rogue Access Point**: an unauthorized wireless access point on the network — the keyword is "unauthorized," not weak or old.
- **Wireless scanning workflow**: Scan → Identify → Compare with inventory → Investigate unknowns → Report.
- **Quarterly testing**: every 3 months, because networks constantly change and new risks appear.

GDPR — Full Recap

- **GDPR** = General Data Protection Regulation — protects personal data of individuals connected to the EU.
- Applies to organizations that are EU-based, work with EU clients, or process EU citizens' data.
- GDPR does **not** give a detailed testing methodology — it just requires that testing and assessment happen.
- **Article 32**: regularly test, assess, and evaluate the effectiveness of security measures — install, test, assess, evaluate, improve.
- **Article 35 / DPIA**: assess privacy risks **before** processing sensitive personal data — a proactive risk assessment, not a reaction to a breach.
- A penetration tester supports both articles by testing security controls, finding vulnerabilities, and recommending fixes.

PCI-DSS vs GDPR — Side-by-Side

Aspect	PCI-DSS	GDPR
Focus	Payment card data	Personal data of EU individuals
Detail level	Very specific requirements (Merchant Levels, ASV, QSA)	General principle: "test and assess"
Testing frequency	Quarterly (for wireless, per Requirement 11)	"Regularly" — not a fixed number specified
Key article/requirement	Requirement 11	Article 32 & Article 35 (DPIA)

The 10 Keywords to Memorize

PCI

DSS

SAQ

ASV

AOC

ROC

QSA

WAP

Rogue AP

DPIA

Instructor's Feedback

Today's lesson was not just about memorizing definitions — it was about learning to think like a penetration tester. Instead of asking "What is this?", start asking: Why is it important? How do I test it? How do I verify it? What evidence do I need? That shift in thinking is one of the biggest steps toward becoming a professional security engineer.

Part 4 · Homework & Self-Check

Homework (10 minutes)

Without looking at your notes, explain these five topics in simple English, in your own words:

- Merchant Levels
- Requirement 11
- Rogue Access Point
- Article 32
- DPIA

If you can teach these five topics to someone else in simple English, you have truly understood them. Get some rest — you've earned it. Tomorrow, continue with fresh energy.